TASK 3: Research Results, Data Analysis and Scientific Visualization

Robustness of text-based phishing detectors to LLM paraphrasing (Cybersecurity track)

Authors: Moldassanov Dias, Bilal Samat | Group: [fill in]
GitHub repository: https://github.com/Dias-M/ResearchMetod-MoldassanovDias-BilalSamat

1. Goal and summary

We measure how much LLM paraphrasing of phishing e-mails lowers the recall of text detectors at a fixed false-positive rate of 1%. Paired design: the same 97 test phishing e-mails are scored in original and paraphrased form by the same detector, 5 seeds, 2231 legitimate test e-mails; the threshold is fixed on validation ham of the original data.

Main result. TF-IDF + LR: recall 0.979 on original vs 0.979 on paraphrased (paired change +0.0 p.p., 95% CI over seeds [+0.0, +0.0]).

2. Method

Data hygiene. Deduplication by SHA-1 of normalised text, removal of conflicting labels, stratified 70/15/15 split by label and source, spam excluded from the negative class (src/phishrobust/data.py). **Outliers** are flagged by the 1.5 x IQR rule on the score margin (score minus threshold) and kept: 25 of 970 rows flagged. There is no warm-up phase in this project (no latency measurements), so nothing is dropped for warm-up.

Statistics. Mean over seeds with a 95% bootstrap CI (10,000 resamples) over seeds; exact McNemar test on the paired detections (one-sided, H1: detection drops), Holm correction across detectors; guardrail: realised FPR must not exceed 2%.

Mathematical model. Scores of original phishing are modelled as normal, paraphrasing as a pure location shift (docs/domain_model.md, section 5; src/signal_model.py). The prediction is not fitted to the paraphrased recall.

3. Results

Detector	Training	Version	Recall, % [95% CI]	FPR, %	F1	Guardrail
TF-IDF + LR	plain	original	97.9 [92.8, 99.4]	0.49	0.936	ok
TF-IDF + LR	plain	paraphrased	97.9 [92.8, 99.4]	0.49	0.936	ok

Table 1. Metrics at the fixed threshold (FPR target 1%), mean over seeds. Seeds give identical numbers (deterministic detector, section 6), so the interval is the 95% Wilson interval over the test e-mails.

Recall before and after LLM paraphrasing (95% Wilson CI over test e-mails; seeds identical, 5 seeds)

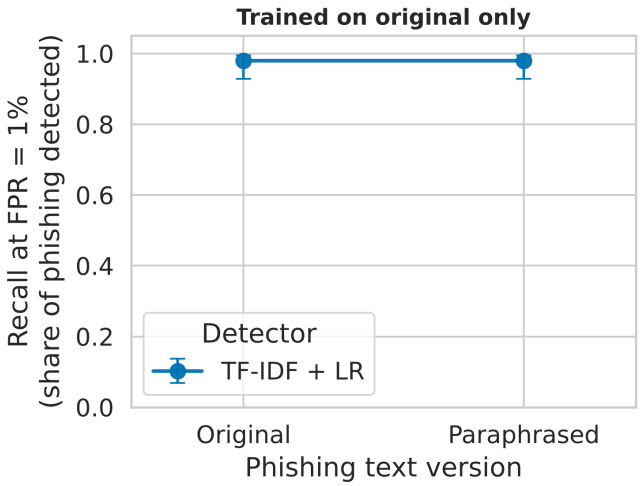


Figure 1. Recall at FPR = 1%, original vs paraphrased; error bars: 95% CI (bootstrap over seeds; Wilson over e-mails if all seeds are identical).

Detector	Pairs	Recall orig	Recall para	Change, p.p. [95% CI]	Lost / gained	Upper 95% bound on lost share	p (Holm)	H0 rejected
TF-IDF + LR	97	0.979	0.979	+0.0 [+0.0, +0.0]	0 / 0	3.0%	1.0000	no

Table 2. RQ1: paired exact McNemar test, one-sided, Holm-adjusted across detectors. Lost = detected in original but missed after paraphrase; gained = the reverse. The bound is the one-sided Clopper-Pearson 95% upper limit of the share of e-mails that get lost.

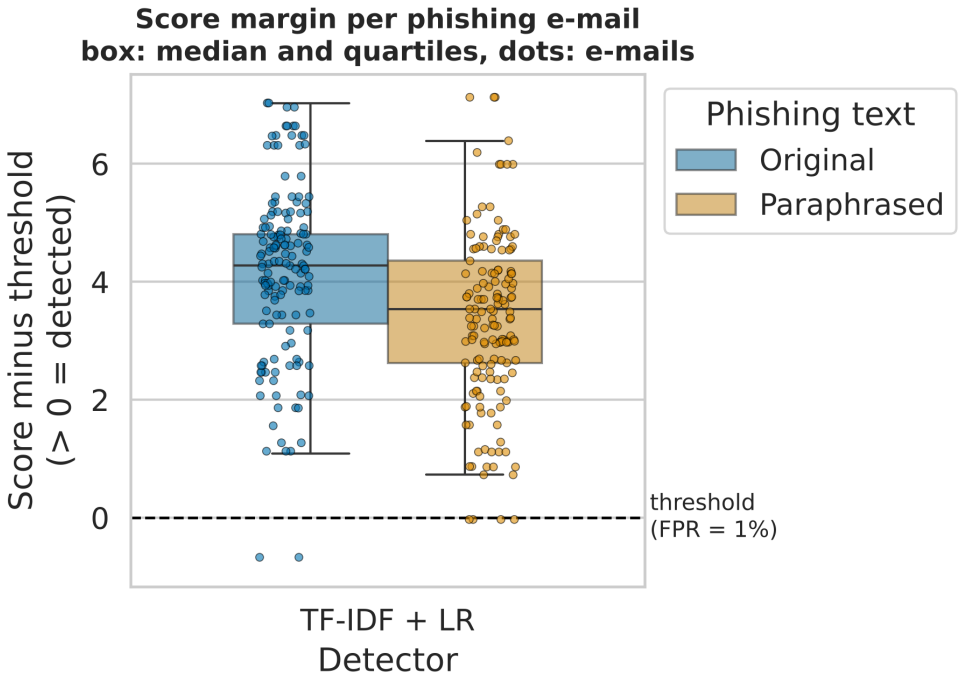


Figure 2. Score margin of every phishing e-mail (box: median and quartiles, dots: e-mails). Values above 0 are detected.

4. Mathematical model vs measurement

Detector	Recall orig (meas. / model)	Recall para (meas. / model)	|error|, p.p.	Score shift [95% CI]	Spread ratio	Median margin
TF-IDF + LR	0.979 / 0.997	0.979 / 0.992	1.2	-0.53 [-0.67, -0.39]	0.98	4.27

Table 3. Location-shift model (not fitted to the paraphrased recall). Spread ratio = SD of paraphrased scores / SD of original scores; values far from 1 or a large error mean that the pure-shift or normality assumption does not hold for that detector. Median margin = median of (score - threshold) of original phishing: how far the typical e-mail sits above the decision threshold.

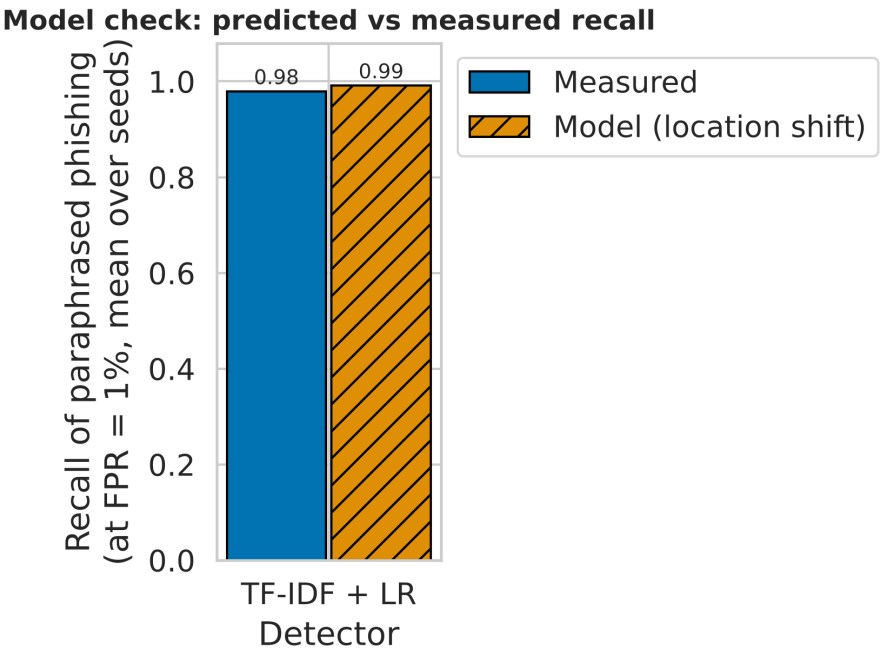


Figure 3. Measured vs predicted recall of paraphrased e-mails.

5. Discussion

TF-IDF + LR. Paraphrasing moves the score by -0.53 (95% CI [-0.67, -0.39]), while the median original e-mail sits 4.27 above the threshold; the model says a shift of -1.10 would be needed to cost 2 p.p. of recall. 0 e-mails were lost, so no drop of recall is visible. A score shift without a recall drop means the detector has a large safety margin on this data (ceiling effect), not that paraphrasing is harmless in general.

The largest gap between model and measurement is 1.2 p.p. (TF-IDF + LR). Where it is small, a paraphrase acts mainly as a shift of the score; where it is large, paraphrasing also changes the shape of the score distribution and the simple model should not be used for that detector.

Limitations. Phishing and legitimate e-mail come from different sources and periods (source/label confound); only paraphrases accepted by the quality filter enter the pairs; meaning drift of paraphrases is not manually audited; paired tests use the first seed only. Run-specific limits (paraphraser, detectors, seeds, data) are listed in section 6.

6. Notes on this run (data, deviations from the plan)

Data. Phishing: Phishing Pot (github.com/rf-peixoto/phishing_pot, CC BY-NC 4.0, commit 80a4867 of 2026-10-28), 12,865 real phishing e-mails collected by honeypots. Legitimate e-mail: CEAS-08, rows with label 0 (github.com/PHP4Life/phishing-email-dataset, file CEAS_08.csv; the same file holds spam, which was not used). Built by scripts/00_build_corpus.py: English only (the corpus is multilingual), near-duplicate campaigns collapsed, then the standard cleaning of scripts/02_prepare_data.py. Result: 1,639 phishing and 14,865 legitimate e-mails; train 11,552, validation 2,475, test 2,477 (246 phishing, 2,231 legitimate).

Leakage removed. Two label giveaways were found and neutralised in both classes before splitting: the anonymiser string "phishing@pot" of the corpus and four-digit years (phishing 2019-2026 against legitimate 2007-2008). The result of the experiment did not change after this step.

Deviation from the plan: the paraphraser. The planned paraphraser (Qwen2.5-1.5B-Instruct) could not run in the environment of this run (no access to the model hub, no deep-learning libraries). Instead 97 phishing e-mails of the test split were paraphrased by Claude, a large language model, with the same instruction (keep the meaning, the links and the addresses; change the wording and the sentence structure). The e-mails were a random sample (seed 0) of the 111 test phishing e-mails of 160 to 900 characters; three explicit adult e-mails were skipped. All 97 paraphrases passed the quality filter (length ratio 0.5 to 1.5, all links kept). The conclusions therefore concern short e-mails and one LLM paraphraser; the paraphrases are in data/processed/paraphrases.csv.

Deviation from the plan: detectors and research questions. Only the TF-IDF + logistic regression detector was run; DistilBERT and the zero-shot LLM need a deep-learning stack that was not available. RQ3 (training with paraphrase augmentation) was not run because it needs paraphrases of the training set. RQ2 (logistic regression with e-mail length) was not run.

Seeds. TF-IDF + logistic regression is deterministic, so the five seeds give identical numbers and a confidence interval over seeds has zero width. Uncertainty is therefore shown by the paired exact test, the Clopper-Pearson bound on the share of lost e-mails, and the confidence interval of the score shift.

Main limitation. Legitimate e-mail (2008 mailing lists and personal mail) and phishing (modern marketing and crypto-wallet HTML e-mail) still differ in style after the cleaning, so the detector separates the two classes easily (recall about 98%) and has a large safety margin. A small effect of paraphrasing can be hidden by this ceiling; the result does not show that paraphrasing is harmless for detectors trained on harder, same-source data. The Phishing Pot honeypot also contains advertising and scam e-mails (casino, pills, lottery), not only credential phishing.

7. Domain model (STRIDE)

STRIDE matrix of the mail gateway, attack tree for the goal 'phishing reaches the inbox' and metric collection points MP-1..MP-4 are in docs/domain_model.md. Threat T2b (evasion by adversarial rewriting) is the one tested experimentally.

8. Repository and reproduction

docs/task3_runbook.md lists the exact commands: download data, prepare, paraphrase, train and evaluate with 5 seeds (plain and augmented), statistics, processing, figures, this report. Environment: exact pins in requirements.txt, Docker image python:3.11.9-slim.